

GIL Business Suite

Technical Architecture & Component Reference

Full Stack System Developer — Technical Assessment

Laravel 12 · Filament 4 · Microsoft SQL Server · PHP 8.2

Covers all three assessment tasks (A/R Invoice, Vehicle Gate Operations, M-Pesa C2B API) and the supporting modules built around them: approvals, routes & trips, the driver portal, audit logging, user administration and error handling.

190 tests · 702 assertions · 61% coverage

Contents

1. Architecture

- 1.1 Layers and dependency direction
- 1.2 Why there is no Repository layer
- 1.3 Directory map

2. Domain models

- 2.1 Sales documents
- 2.2 Payments
- 2.3 Operations
- 2.4 Master data
- 2.5 Platform

3. Services

4. Support & value objects

5. HTTP layer

6. Events & listeners

7. Presentation (Filament)

8. Console commands

9. Platform & configuration

10. Database schema

11. Request lifecycles

12. Cross-cutting decisions

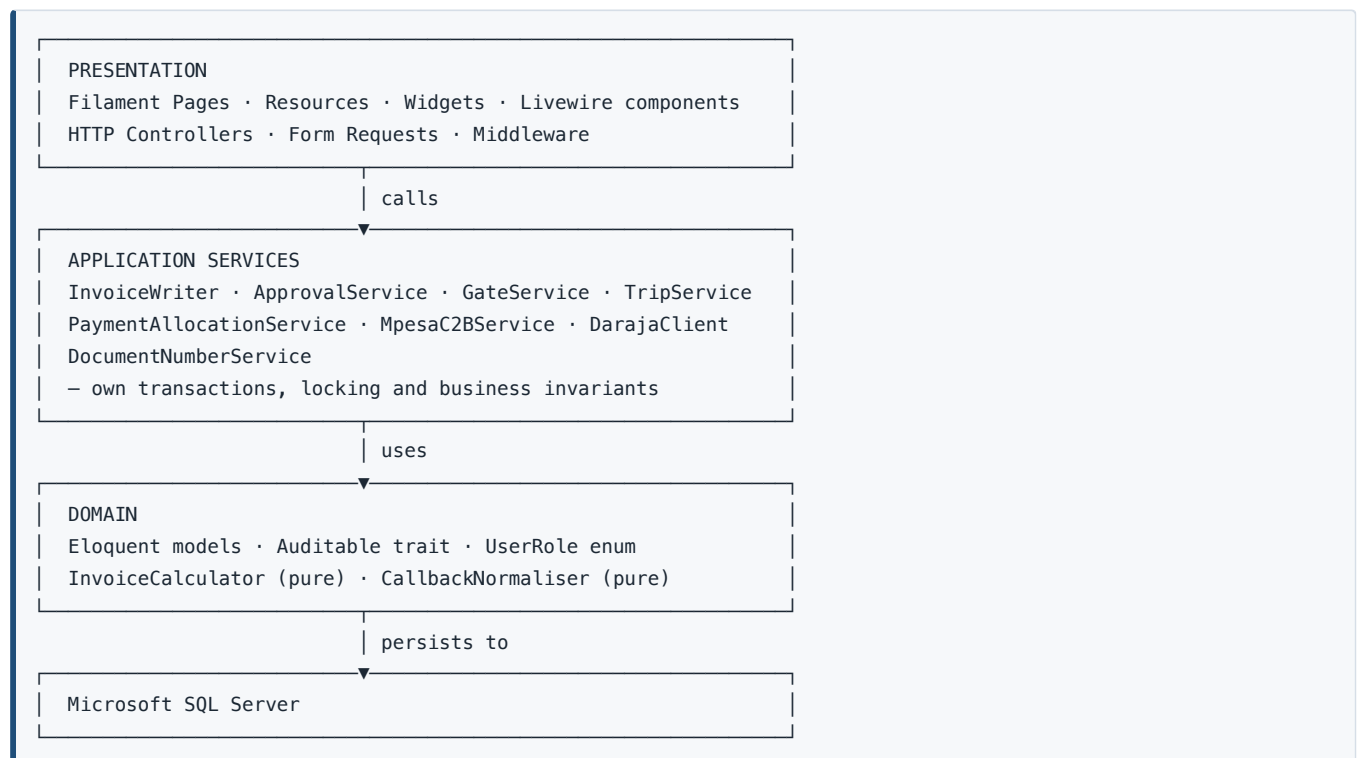
13. Testing

14. Operations runbook

1. Architecture

1.1 Layers and dependency direction

The application is a layered Laravel monolith. Dependencies point inward only: presentation depends on services, services depend on models, and nothing in the inner layers knows anything about Filament, HTTP or Livewire.



The rule that keeps this honest: **a service may never receive a Livewire component, a Request, or a Filament schema**. It receives arrays and models. That is why every service can be exercised from a test, a console command or an HTTP callback without touching the UI.

1.2 Why there is no Repository layer

There is deliberately no `app/Repositories` directory. A repository abstracts persistence so the domain can be ignorant of the store. Eloquent already is that abstraction — it is an Active Record implementation of the same idea. Wrapping it in a second interface would add a layer that this application never varies: there is exactly one database, one ORM, and no prospect of swapping either.

What repositories are usually reached for — *keeping query logic out of controllers* — is solved here by two cheaper mechanisms:

- **Query scopes on models** — `Invoice::outstanding()`, `Trip::forDriver()`, `GateLog::open()`. Named, reusable, testable, and they compose.
- **Services for anything that writes** — a write that must be atomic, locked or validated lives in a service, never in a controller or a Filament page.

The one place a repository-shaped object *does* appear is `ChooseFromListRegistry` (§4.1), which centralises read queries for the picker precisely because those queries are chosen by the browser and must be whitelisted.

1.3 Directory map

Path	Contains
<code>app/Models</code>	19 Eloquent models + the <code>Auditable</code> concern
<code>app/Services</code>	9 application services — all business writes
<code>app/Support</code>	Pure helpers with no database or framework dependency
<code>app/Enums</code>	<code>UserRole</code> — the capability matrix
<code>app/Http</code>	The M-Pesa API surface: controller, form request, middleware
<code>app/Events</code> , <code>app/Listeners</code>	Decoupling of payment capture from reconciliation, and session capture
<code>app/Filament</code>	Panel UI: 4 custom pages, 13 resources, 1 widget, 1 concern
<code>app/Livewire</code>	<code>ChooseFromList</code> — the shared SAP-style picker
<code>app/Console/Commands</code>	Two operational commands
<code>app/Exceptions</code>	Error shaping for three different audiences
<code>database/migrations</code>	20 migrations
<code>tests/Unit</code> , <code>tests/Feature</code>	5 unit suites, 17 feature suites

2. Domain models

Nineteen Eloquent models. Ten of them use the `Auditable` concern, so every create, update and delete is attributed to a person.

2.1 Sales documents

Invoice MODEL

app/Models/Invoice.php · table: invoices (39 columns)

The A/R document. Holds the header, the totals block and the document lifecycle. Deliberately fat with *snapshots*: `customer_code`, `customer_name`, `contact_person`, `kra_pin`, `sales_employee_name` and `owner_name` are copied onto the row at save time so that later edits to master data cannot rewrite the history of a posted document.

Member	Purpose
<code>APPROVAL_THRESHOLD</code>	10,000 — the figure the brief specifies for routing to approval.
<code>TYPE_INVOICE</code> / <code>TYPE_DRAFT</code>	A draft is a scratchpad: never approved, never a receivable, carries no balance.
Status constants	<code>Draft</code> , <code>Open</code> , <code>Pending Approval</code> , <code>Rejected</code> , <code>Closed</code> , <code>Cancelled</code> .
<code>lines()</code>	HasMany <code>InvoiceLine</code> , ordered by <code>line_num</code> .
<code>approvalRequests()</code> / <code>pendingApproval()</code>	Full history, and the single open request if there is one.
<code>allocations()</code>	HasMany <code>PaymentAllocation</code> — the M-Pesa receipts applied to it.
<code>scopeOutstanding()</code>	Posted, balance > 0, not cancelled or rejected. This is the set a payment may target.
<code>scopeDrafts()</code> / <code>scopePosted()</code>	Split by <code>doc_type</code> .
<code>getDocumentNumberAttribute()</code>	Renders <code>IN-00000002</code> from series + zero-padded number.
<code>acceptsPayment()</code>	The single predicate for "can money be applied here" — not a draft, not cancelled/rejected, balance remaining.

InvoiceLine MODEL

app/Models/InvoiceLine.php · table: invoice_lines (23 columns)

One row of the document grid. Stores both the *net* figures (`price_after_discount`, `line_total`) and the *gross* figures that include VAT (`gross_price_after_discount`, `gross_total`), matching the sample document which shows both. Casts prices at 4 d.p. and `discount_percent` at 6 d.p.

ApprovalRequest MODEL

app/Models/ApprovalRequest.php · table: approval_requests (12 columns)

One decision on one over-threshold invoice. Records the amount *and* the threshold at the time, so a later change to the threshold does not retroactively alter why a document was routed. `requested_by` is nullable — a request opened by the repair command genuinely has no requester. `scopePending()` is what the queue and the "stuck" detector both use.

DocumentSeries MODEL

app/Models/DocumentSeries.php · table: document_series (6 columns)

A counter row per (`document_type`, `series`). Exists so that document numbering can be locked; see `DocumentNumberService` (§3.1).

2.2 Payments

MpesaTransaction MODEL

app/Models/MpesaTransaction.php · table: mpesa_transactions (21 columns)

One received C2B callback. Every documented Daraja field has its own `nvarchar` column — the brief's requirement — plus `raw_payload` holding the body exactly as Safaricom sent it, so anything added later is never silently dropped.

Member	Purpose
TYPE_VALIDATION / TYPE_CONFIRMATION	Which of the two registered URLs received it. Only a confirmation is money.
Allocation constants	Pending , Matched , Partial , Unmatched , N/A (a cancelled STK push).
getUnallocatedAmountAttribute()	Received minus applied — what is still available to allocate.
getTransactedAtAttribute()	Parses <code>TransTime</code> (<code>yyyyMMddHHmmss</code>) into a date <i>for display only</i> ; the column stays a string per the brief. Returns null rather than throwing on malformed input.
getPayerNameAttribute()	Joins first/middle/last, skipping blanks.

PaymentAllocation MODEL

app/Models/PaymentAllocation.php · table: payment_allocations (9 columns)

The join between a receipt and an invoice, carrying the amount applied. Unique on (`mpesa_transaction_id`, `invoice_id`). `matched_by` distinguishes `auto` (BillRefNumber matched) from `manual` (an admin allocated it), and `allocated_by` records who did.

2.3 Operations

GateLog MODEL

app/Models/GateLog.php · table: gate_logs (17 columns)

One vehicle movement. Driver name, ID and phone are snapshotted at gate-in: the person who drove in must remain on the record even if the driver master changes. `scope0open()` is the basis of "currently on site" and of the Gate Out screen's filtered vehicle list. `getDurationAttribute()` renders time on site as `2h 15m`.

Trip MODEL

app/Models/Trip.php · table: trips (17 columns)

A journey: a vehicle and driver assigned to a route. Statuses run `Scheduled` → `In Transit` → `Completed`, with `Cancelled` as an exit. Route, vehicle and driver names are snapshotted.

Security-critical: `scopeForDriver()` coalesces a null driver id to `0`, so a login with no linked driver record matches *nothing* rather than everything. This is the difference between an empty portal and a data breach.

Route MODEL

app/Models/Route.php · table: routes (10 columns)

Origin, destination, distance and estimated hours. `getPathAttribute()` renders `Nairobi → Mombasa`.

2.4 Master data

Model	Table	Notes
Customer	customers	Code, name, contact, currency, KRA PIN. The source of the invoice header snapshot.
Item	items	Item no., description, UoM, warehouse, unit price (4 d.p.), stock on hand.
SalesEmployee	sales_employees	Code, name, position.
Vehicle	vehicles	Registration, make, type. <code>scopeCurrentlyGatedIn()</code> drives the Gate Out list.
Driver	drivers	Name, national ID, phone. Optional <code>user_id</code> link to a login.
VatCode	vat_codes	O0 (zero-rated, default), V16, V8, E. <code>default()</code> supplies new lines.
Warehouse	warehouses	Code, name, location, default flag.

2.5 Platform

User **MODEL**

app/Models/User.php · table: users (11 columns)

Implements Filament's `FilamentUser`. Casts `role` to the `UserRole` enum.

Member	Purpose
<code>canAccessPanel()</code>	Deactivated accounts keep their history but cannot sign in.
<code>role()</code>	Never-null accessor, defaulting to Sales.
<code>driver()</code> / <code>driverId()</code>	The driver record this login represents, if any. The driver portal scopes on this.
<code>canApproveAmount()</code>	Role must permit approval <i>and</i> the amount must be within <code>approval_limit</code> (null = unlimited).

AuditLog **MODEL**

app/Models/AuditLog.php · table: audit_logs (15 columns)

One recorded change. Stores the actor (id *and* snapshotted name and role), the event, a polymorphic reference to the record, a human label (`IN-00000002`), the changed fields only, and request context. `getChangesListAttribute()` pairs old and new into the diff view.

LoginSession **MODEL**

app/Models/LoginSession.php · table: login_sessions (9 columns)

The durable login trail Task 2 requires: who signed in, when, from which IP and agent, and when they left. Distinct from Laravel's own `sessions` table, which is a garbage-collected cache of session payloads.

Auditable **CONCERN**

app/Models/Concerns/Auditable.php

A trait booted into ten models. Hooks `created` , `updated` and `deleted` and writes an `AuditLog` row.

Behaviour	Rationale
Records changed attributes only	Dumping whole rows makes the trail unreadable and duplicates data.
Skips no-op saves and <code>touch()</code>	A log full of "updated_at changed" hides the entries that matter.
Two independent secret guards	An explicit exclude list (<code>password</code> , <code>remember_token</code>), <i>and</i> a regex rejecting any key matching <code>password token secret api_key</code> — so a column added later cannot leak by omission.
Snapshots actor name and role	The log must still read correctly after a user is renamed or deactivated.
<code>auditLabel()</code>	Picks the most human identifier available: document number, reference, code, plate, TransID, name, email.

3. Services

Every business write goes through a service. Each owns its own transaction and locking; none of them know about HTTP or Filament.

3.1 DocumentNumberService SERVICE

app/Services/DocumentNumberService.php

Issues the sequential "No." on the invoice header.

Method	Behaviour
<code>next(\$type, \$series)</code>	Locks the counter row <code>FOR UPDATE</code> , reads it, increments atomically with <code>DB::raw('next_number + 1')</code> , returns the number.
<code>peek(\$type, \$series)</code>	Reads the next number without consuming it — what the screen displays before saving.

Why not `MAX(doc_num) + 1`: two simultaneous saves would read the same maximum and both attempt to insert it. The counter row is locked *inside the caller's transaction*, so the second save blocks until the first commits and then sees the incremented value.

It refuses to run outside a transaction. `next()` throws a `LogicException` if `DB::transactionLevel() === 0`, because the lock would be released immediately and duplicates issued silently. Failing loudly beats corrupting the sequence.

3.2 InvoiceWriter SERVICE

app/Services/InvoiceWriter.php · depends on DocumentNumberService, ApprovalService

Turns the A/R Invoice screen's form state into a persisted document. Lives outside the Livewire page so the same write path is reachable from a test, an import or a command.

`store(array $state, int $userId, bool $asDraft = false): Invoice` — in order:

1. Drops blank trailing lines (the grid always shows one).
2. Rejects a document with no usable lines.
3. **Resolves VAT rates server-side** from the chosen code — a rate posted from the browser is display state, and trusting it would let a client set their own tax.
4. **Recomputes every total** via `InvoiceCalculator`.
5. Opens a transaction; reserves the document number under a row lock.
6. Writes the header with master-data snapshots, then the lines.
7. Calls `ApprovalService::requestIfNeeded()` *in the same transaction*, so a document is never committed as "Pending Approval" without a matching queue entry.

3.3 ApprovalService SERVICE

app/Services/ApprovalService.php

Method	Behaviour
<code>requestIfNeeded()</code>	Opens a request when the document breached the threshold and is not a draft. Guards against a duplicate open request. Accepts a null requester (system repair).
<code>approve()</code>	Moves the invoice to <code>Open</code> , or <code>Closed</code> if already settled.
<code>reject()</code>	Requires a non-blank reason; marks the invoice <code>Rejected</code> .
<code>decide()</code> (<i>protected</i>)	The shared path both decisions run through, so they cannot drift apart.

Three guards inside `decide()` : the request is re-read `FOR UPDATE` and re-checked as still pending (two approvers opening the same queue entry must not both record a decision); the decider's role and `approval_limit` are verified against the amount; and the invoice row is itself locked before its status changes.

3.4 PaymentAllocationService SERVICE

`app/Services/PaymentAllocationService.php`

Applies M-Pesa receipts to invoices. Without this, the C2B endpoint is a write-only log: money arrives and nobody knows what it settled.

Method	Behaviour
<code>autoAllocate()</code>	Confirmations only. Resolves <code>BillRefNumber</code> to an invoice and applies the receipt. Returns null — not an error — when nothing matches; a mistyped reference is a normal business event.
<code>findInvoiceByReference()</code>	Tolerates <code>IN-2</code> , <code>INV-2</code> , <code>IN2</code> , <code>2</code> , <code>in 2</code> . Honours an explicit series prefix. Refuses to guess when a bare number is ambiguous across series — paying the wrong invoice is worse than queuing for a human.
<code>allocate()</code>	Locks both invoice and receipt, verifies the invoice accepts payment, caps the application at the outstanding balance, and writes the allocation idempotently.
<code>unallocate()</code>	Removes an allocation and restores both balances.
<code>refreshInvoiceBalance()</code> (<i>protected</i>)	Recomputes applied/balance by summing the allocation rows , never by incrementing a running total — so the figures cannot drift from the records that justify them.
<code>statusAfterPayment()</code> (<i>protected</i>)	Closes a fully paid document, but never promotes an invoice past its approval step just because it was paid.

Overpayment: a 27,920 receipt against a 22,920 balance applies 22,920 and leaves 5,000 unallocated *on the receipt*. The invoice never goes negative; the excess stays visible for allocation elsewhere or refund.

3.5 MpesaC2BService SERVICE

`app/Services/MpesaC2BService.php`

Parses and persists callbacks. `FIELD_MAP` is the single declaration of the callback-field → column mapping, reused by the form request's error attribute names and by the docs.

Method	Behaviour
<code>store()</code>	Writes keyed on <code>(trans_id, callback_type)</code> so a Safaricom retry updates rather than duplicates. Marks a failed STK push <code>N/A</code> . Otherwise dispatches <code>C2bConfirmationReceived</code> .
<code>parse()</code>	Maps the body onto columns, case-insensitively — sandbox and production have differed on casing (<code>MSISDN</code> vs <code>msisdn</code>) and a mismatch would silently store a null amount.
<code>stringify()</code> (<i>protected</i>)	Casts scalars to strings; JSON-encodes anything structured rather than throwing, so one malformed field cannot reject a valid payment. Amounts are never cast to float — no precision is lost.
<code>missingFields()</code> / <code>unmappedFields()</code>	Reported back in the response so an integrator can see what Safaricom did and did not send.

3.6 DarajaClient SERVICE

`app/Services/Mpesa/DarajaClient.php`

Outbound calls to Safaricom. The callback endpoints are useless until Safaricom has been told where to send traffic, and that registration is itself an authenticated API call.

Method	Behaviour
<code>accessToken()</code>	OAuth token, cached 50 minutes — Daraja issues short-lived tokens and rate-limits the auth endpoint. Throws rather than returning empty on failure.
<code>registerUrls()</code>	POSTs <code>ShortCode</code> , <code>ResponseType</code> , <code>ConfirmationURL</code> , <code>ValidationURL</code> to <code>/mpesa/c2b/v1/registerurl</code> . Refuses a localhost URL — Safaricom accepts such a registration and then never delivers, which presents as "the callback never fires".
<code>status()</code>	Reports environment, host, short code and which config is missing.

`ResponseType` defaults to `Completed` : if the Validation URL is unreachable the payment is accepted anyway, so an outage never turns paying customers away. The receipt is reconciled afterwards.

3.7 GateService SERVICE

`app/Services/GateService.php`

Owns the single invariant of Task 2: **a vehicle can only be inside once**. Both screens go through here rather than each enforcing it.

Method	Behaviour
<code>gateIn()</code>	Locks the vehicle row, rejects if an open log exists, snapshots driver details, auto-captures <code>time_in</code> and the recording user.
<code>gateOut()</code>	Locks the open log, rejects if none, stamps <code>time_out</code> and the recording user. The original gate-in user is preserved.
<code>openLogFor()</code>	The open record for a vehicle, optionally locked. Used by both the screens and the warning shown while typing.

3.8 TripService SERVICE

`app/Services/TripService.php` · depends on `DocumentNumberService`

Method	Behaviour
<code>schedule()</code>	Allocates a <code>TRP-nnnnnn</code> reference, snapshots route/vehicle/driver, and refuses to double-book a vehicle or driver already on an open trip (checked under a lock).
<code>depart()</code> / <code>arrive()</code> / <code>cancel()</code>	Status transitions, each with an explicit set of legal predecessors.
<code>transition()</code> (<i>protected</i>)	The one place the legal transitions live — a completed trip can never go back to scheduled.

4. Support & value objects

4.1 InvoiceCalculator

app/Support/InvoiceCalculator.php · pure — no database, no framework

The single source of truth for invoice arithmetic. The live form recalculates on every keystroke and the save path recalculates again before writing; if those two disagreed, a user could post totals that do not match their own lines. Both call this class.

Precision

Constant	Value	Applies to
SCALE	4	Unit prices, line and document money — the sample shows KES 1,850.0000
PERCENT_SCALE	6	Discount % — the sample shows 5.405405
TOTAL_SCALE	2	Total (LC), Gross Total (LC), the footer block
QTY_SCALE	3	Quantities

Money is *computed and stored* at 4 d.p. and only *displayed* at 2, so a rounded presentation never becomes a rounded stored value. `DISPLAY_SCALES` maps each field to its rendering precision and `display()` formats it.

Rules

Method	Rule
<code>priceAfterDiscount()</code>	$\text{price} \times (1 - \text{discount}/100)$, discount clamped to 0–100.
<code>lineTotal()</code>	$\text{quantity} \times \text{discounted price}$.
<code>recalculateLine()</code>	Derives price after discount, line total, VAT amount, gross price and gross total. VAT is computed on the line total, not the unit price , so rounding happens once per line rather than once per unit.
<code>documentTotals()</code>	The whole footer in one call: before/after discount, tax, freight, rounding, down payment, document total, applied, balance.
<code>isBlankLine()</code>	Identifies the empty trailing row the grid always shows, so it is neither saved nor counted.

A document discount scales the tax with it. The taxable base falls when a document-level discount is applied, so $\text{tax} = \text{lineVat} \times (\text{after} \div \text{before})$. Taking line VAT untouched would over-declare VAT to KRA. Similarly **balance never goes negative** — an overpayment belongs on the receipt, not as a negative receivable.

4.2 ChooseFromListRegistry

app/Support/ChooseFromListRegistry.php

A whitelist of the record lists the SAP-style picker may open. Seven sources: `customers_by_code`, `customers_by_name`, `items`, `sales_employees`, `vehicles`, `vehicles_gated_in`, `drivers`.

This is a security boundary. The browser sends a *key* from this registry, never a model class or a query. Anything not listed throws. Without it, an edited payload could point the picker at any table in the database.

Each entry declares its model, heading, displayed columns, searchable columns, sort and an optional query filter.

`customers_by_name` exists purely so the Name list leads with the customer name, as the brief specifies, while `customers_by_code` leads with the code. `vehicles_gated_in` applies `currentlyGatedIn()` — this is what makes the Gate Out screen show only vehicles on site.

4.3 CallbackNormaliser

`app/Services/Mpesa/CallbackNormaliser.php` · pure

Flattens the two payload shapes that are both called "C2B".

	C2B Register URL	STK Push
Shape	flat	nested under <code>Body.stkCallback</code>
Amount	<code>TransAmount</code>	<code>Amount</code> in <code>CallbackMetadata.Item[]</code>
Receipt	<code>TransID</code>	<code>MpesaReceiptNumber</code>
Payer	<code>MSISDN</code> , <code>names</code>	<code>PhoneNumber</code> only

The brief names `TransAmount`, which exists only in the Register-URL payload — so that is the primary implementation. But nothing stops an integrator pointing an STK callback at the same URL, and parsing only the flat shape would store a row of nulls and lose the payment. A failed push falls back to the checkout id so the attempt is still uniquely keyed, and `isSuccessful()` reports whether money actually moved (`ResultCode 0`) — a cancelled push (1032) or timeout (1037) is recorded but never allocated.

4.4 UserRole enum

`app/Enums/UserRole.php`

Five roles with explicit capability predicates rather than a permissions table.

Role	Capabilities
Admin	all seven: sell, approve, gate, administer, view payments, manage trips, view audit log
Sales	<code>canSell</code> , <code>canViewPayments</code>
Approver	<code>canApprove</code> , <code>canViewPayments</code>
Gate Officer	<code>canOperateGate</code> , <code>canManageTrips</code>
Driver	<code>isDriver</code> only

An ACL table is machinery for configuration that will never happen: five clearly separated jobs, fixed at build time. A wrong answer here is a security hole, so the matrix is pinned by a data-provider test that asserts each role has *exactly* its own capabilities and no others.

5. HTTP layer

The only public HTTP surface is the M-Pesa callback API. Everything else is behind the authenticated Filament panel.

MpesaC2BController **CONTROLLER**

app/Http/Controllers/Api/MpesaC2BController.php

Two actions, `confirmation()` and `validation()`, both delegating to a shared `ingest()`. Carries the Scribe annotations that generate the published API reference.

- Persists first, then responds.
- On failure: logs with full context and returns `ResultCode: 1` with HTTP 500 so Safaricom *retries*.
- On success: `ResultCode: 0` plus a structured confirmation echoing every captured field, the payer name, the parsed transaction time, and which fields were missing or unrecognised.

On always answering `ResultCode: 0` : a common pattern is to swallow every error and always accept, so Safaricom never retries. That trades a retry for silent data loss — if the write failed, the payment is gone from your books. Here the non-zero response is deliberate: combined with the `(trans_id, callback_type)` unique index, a retry updates the existing row rather than paying twice. At-least-once delivery plus idempotency beats at-most-once.

MpesaC2BCallbackRequest **FORM REQUEST**

app/Http/Requests/MpesaC2BCallbackRequest.php

Validation, normalisation and documentation of the callback body.

Member	Purpose
<code>rules()</code>	Only <code>TransID</code> is required — it is the idempotency key. Everything else is nullable but length-bounded so a malformed or hostile body cannot overflow a column. Deliberately permissive: Safaricom is the caller, and rejecting a payment we do not perfectly recognise loses money.
<code>prepareForValidation()</code>	Detects the payload shape, flattens an STK body via <code>CallbackNormaliser</code> , and casts scalars to strings. Uses <code>replace()</code> not <code>merge()</code> , so the nested <code>Body</code> key never survives into validation.
<code>attributes()</code>	Keeps Safaricom's own field names in errors — Laravel would otherwise render <code>TransID</code> as "trans id".
<code>failedValidation()</code>	Throws a <code>ResultCode</code> -shaped 422. Laravel's default body would not be recognised by Safaricom's parser.
<code>bodyParameters()</code>	Field descriptions for the generated docs, kept beside the rules they describe so the reference cannot drift from what the code accepts.
<code>originalPayload()</code> , <code>shape()</code> , <code>isSuccessfulPayment()</code>	Expose the pre-flattening body and whether money actually moved.

AllowMpesaCallbacks **MIDDLEWARE**

app/Http/Middleware/AllowMpesaCallbacks.php • alias `mpesa.callback`

The endpoints cannot be authenticated — Safaricom sends no credentials — so they are restricted to an allow-list of its published callback IPs (`MPESA_ALLOWED_IPS`). An empty list disables the check, which is what sandbox and local development need. Rejections are logged and answered tersely: an unknown caller is told nothing about why.

Rate limiting

Registered in `AppServiceProvider` as the `mpesa` limiter: 120/minute keyed on **short code + MSISDN**, not IP. Every callback arrives from the same small pool of Safaricom addresses, so an IP-keyed limiter would throttle every merchant at once.

6. Events & listeners

`C2bConfirmationReceived` → `AllocateMpesaReceipt`

app/Events · app/Listeners

Fired once a receipt is captured; the listener matches it to the invoice named in `BillRefNumber`.

Why an event rather than an inline call: recording that money arrived is the part that must never fail. Deciding which invoice it settles is business logic that may legitimately fail or change. The split means a reconciliation bug cannot prevent capture — the listener catches, logs and marks the receipt `Unmatched` for manual allocation. A test mocks the allocator to throw and asserts the receipt still survives.

`RecordLoginSession` / `RecordLogout`

app/Listeners · auto-discovered from Laravel's Login / Logout events

Write and close `login_sessions` rows — the durable trail Task 2 requires. `RecordLogout` selects the latest open session by id *before* updating, because SQL Server does not accept `ORDER BY` on an `UPDATE`.

7. Presentation (Filament)

7.1 Custom pages

ArInvoice PAGE

app/Filament/Pages/ArInvoice.php · ~700 lines · route /admin/ar-invoice

Task 1. The largest component in the system, built as a custom page rather than a Filament resource because the layout is a dense SAP document, not a web form.

Section	Contents
<code>headerSection()</code>	Customer / Name (both Choose-From-List <i>and</i> type-ahead), Contact Person, the separate bold Customer Name, BP Currency, KRA PIN; series + auto number, Status, Posting / Value / Document dates; and the approval label.
<code>contentTabs()</code>	Six tabs — Contents, Logistics, Accounting, Attachments, TIMS, ETIMS — plus the Item/Service Type and Summary Type strip above the grid.
<code>linesRepeater()</code>	The 14-column grid: #, Item No., Description, Quantity, Whse, Qty in Whse, UoM, Unit Price, Discount %, Price after Discount, VAT Code, Gross Price after Disc., Total (LC), Gross Total (LC).
<code>footerSection()</code>	Sales Employee, Owner, Payment Order Run, mandatory Remarks, QRCode; and the totals block through to Balance Due.

Live behaviour

- `applyCustomer()` — fills contact, currency and PIN, and mirrors the selection between the Code and Name fields.
- `applyItem()` — fills description, UoM, warehouse, stock and price; defaults quantity to 1.
- `applyVatCode()` — re-reads the rate from the chosen code, never from posted state.
- `recalculateAllTotals()` — always derives from `$this->data` rather than a component-relative getter, so it is correct no matter which field or repeater row triggered it.

Validations

Discount > 50 rejected on both line and document with an explicit message; Remarks mandatory; quantity numeric only.

Actions

`Add & New` (posts), `Add Draft & New` (saves a draft), `Cancel` (confirms, then clears), `Copy From` (pulls lines from an earlier document **for the same customer only** — copying across customers would leak one customer's pricing into another's), and `Copy To`, deliberately disabled with a tooltip because no downstream document type exists yet.

VehicleGateIn / VehicleGateOut PAGES

app/Filament/Pages · routes /admin/vehicle-gate-in, /admin/vehicle-gate-out

Task 2. Single column on a phone, two from the medium breakpoint up, with larger touch targets on small screens.

- **Gate In** — searchable Vehicle and Driver; Driver ID and Phone auto-populate; selecting a vehicle already inside warns immediately (the service still enforces it under a lock at save).
- **Gate Out** — the vehicle list is `vehicles_gated_in`, so only vehicles with an open record appear. Driver details, time in and time on site are read back from that record.

Both show a live "Currently On Site" panel beneath the form.

MyTrips PAGE

app/Filament/Pages/MyTrips.php · route /admin/my-trips

The driver portal. Trip cards sized for a phone in a cab, showing only the action legal from the current status.

Two independent guards. `canAccess()` requires the Driver role *and* a linked driver record. `ownedTrip()` then re-checks ownership server-side on every action, scoping by driver *before* the key lookup — so a foreign trip id 404s rather than resolving. The id arrives from the browser and is never trusted.

7.2 Resources

Resource	Access	Purpose
InvoiceResource	<code>canSell</code>	Read-only register. No create or edit — a posted invoice is an accounting record, not an editable row. <code>ViewInvoice</code> renders the full document.
ApprovalRequestResource	<code>canApprove</code>	The queue, filtered to Pending by default. Approve (optional note) / Reject (reason required). Badge shows pending count and, in red, any stuck invoices.
GateLogResource	<code>canOperateGate</code>	Movement audit trail; badge shows vehicles on site.
MpesaTransactionResource	<code>canViewPayments</code>	Captured receipts with allocation status, the invoice applied to, a raw-payload viewer, and the manual Allocate action.
TripResource / RouteResource	<code>canManageTrips</code>	Trip planning and route master.
UserResource	<code>canAdminister</code>	User administration — see §7.4.
AuditLogResource	<code>canViewAuditLog</code>	Read-only trail with a red/green field diff. Create, edit and delete are all <code>false</code> — a log you can edit is not a log.
Customer, Item, SalesEmployee, Vehicle, Driver	<code>canAdminister</code>	Master-data CRUD.

7.3 Shared UI components

ChooseFromList LIVEWIRE

app/Livewire/ChooseFromList.php

The SAP "Choose From List" picker. **One instance per page**, re-targeted at whichever field asked for it, so every CFL button shares a single searchable, sortable, paginated modal rather than each shipping its own.

Flow: a field's suffix action dispatches `open-choose-from-list` with a registry key and the field's state path → the component validates the key against the registry, resets the table and opens → choosing a row dispatches `choose-from-list-selected` back to the page.

InteractsWithChooseFromList CONCERN

app/Filament/Concerns/InteractsWithChooseFromList.php

Shared by the invoice and both gate pages. Provides the orange drill-arrow action and, critically, `isWritableStatePath()`.

Two checks on a browser-supplied path: it must start with `data.` (so the picker cannot overwrite arbitrary public properties on the component), and it must not contain `*` — because `data_set()` treats that as a wildcard and would write the chosen id into *every* sibling key. Both are covered by tests.

OperationsOverview WIDGET

app/Filament/Widgets/OperationsOverview.php

The dashboard. Each stat is gated on the signed-in role, so a gate officer never sees a revenue readout: invoiced today and outstanding balance (sales, approver), awaiting approval (approver), vehicles on site (gate), unmatched receipts (payments).

7.4 User administration

`UserForm` handles role, approval limit and the driver link. Passwords are hashed on the way in, and leaving the field blank on edit keeps the existing one rather than blanking it. The driver link is applied *after* save (it lives on the drivers table), and any previous link is released first so a driver record can never be attached to two logins.

Self-lockout guards: an admin cannot change their own role or deactivate their own account (both fields disable themselves for the signed-in user), and cannot delete themselves.

8. Console commands

mpesa:register-urls

app/Console/Commands/RegisterMpesaUrls.php

Registers the Validation and Confirmation URLs with Safaricom — the one-time setup without which the endpoints never receive traffic. `--status` reports configuration without sending anything. Registration is an outward-facing change to a live short code, so it is confirmed interactively rather than run silently, and refuses a localhost URL.

invoices:repair-approvals

app/Console/Commands/RepairApprovalRequests.php

Finds invoices marked `Pending Approval` with no open request — documents stuck in limbo, invisible because the approvals list filters to Pending by default. Opens the missing request, recomputing a missing document total from the invoice's own lines. `--dry` reports without writing. Idempotent.

9. Platform & configuration

AdminPanelProvider

app/Providers/Filament/AdminPanelProvider.php

Configures the panel: SAP navy primary colour, full content width, the custom theme, and `darkMode(false)` — the sample document is a light desktop client, and honouring an OS dark preference would stop it matching.

Handler EXCEPTIONS

app/Exceptions/Handler.php · wired in bootstrap/app.php

Shapes errors for three audiences.

Caller	Response
Safaricom (/api/mpesa/*)	<code>resultCode</code> JSON — an HTML error page would be parsed as failure and retried forever.
Other API clients	<code>{success, message, reference}</code>
Panel users	A branded page with a quotable reference id.

`safeMessage()` returns a deliberately generic string for any 5xx: the real exception routinely names tables, columns and file paths. Each incident is logged with a short reference (`1ENYC2JU`), URL, method, IP and user id.

`shouldReport()` treats validation, auth and 404 as ordinary control flow — only 5xx is an incident.

Custom theme

`resources/css/filament/admin/theme.css` carries the SAP appearance: navy title bar with window chrome, captions left of hairline field boxes, collapsed schema gaps for density, the dense line grid with CSS-counter row numbers and ruled filler rows, blue right-aligned money, and the driver portal's trip cards.

Three layout traps worth recording, all found by measuring rather than reading: flex/grid children default to `min-width: auto` so a wide grid stretches the page instead of scrolling; Filament renders `hiddenLabel()` captions as `position: absolute` screen-reader spans that escape a scroll container unless it is itself positioned; and a table stretches its rows to fill a container with a min-height, so the filler-row effect needs an explicit row height.

10. Database schema

Twenty migrations against Microsoft SQL Server.

Table	Cols	Notable constraints and columns
invoices	39	unique(series, doc_num) — numbering is per series, so IN-5 and CR-5 coexist. FKs to customers, sales_employees, users (owner, creator). Indexed on posting_date, customer_code, doc_type, status.
invoice_lines	23	unique(invoice_id, line_num); cascade delete with the invoice. Net and gross money at 4 d.p.; discount at 6.
document_series	6	unique(document_type, series) — makes the create-if-missing race safe.
approval_requests	12	Nullable requested_by (system repairs). Indexed on (status, requested_at) and invoice_id.
mpesa_transactions	21	unique(trans_id, callback_type) — the idempotency guarantee. Every Daraja field its own nvarchar; raw_payload JSON. Indexed on msisdn, bill_ref_number, allocation_status.
payment_allocations	9	unique(mpesa_transaction_id, invoice_id) — a receipt applies to a given invoice at most once.
gate_logs	17	Two FKs to users with no cascade — SQL Server rejects multiple cascade paths into one table. Indexed on (vehicle_id, status).
trips	17	unique reference; indexed on (driver_id, status) and (vehicle_id, status).
routes	10	unique code.
audit_logs	15	Polymorphic (auditable_type, auditable_id); JSON old/new values. Indexed on the morph pair, (user_id, created_at), event, created_at.
login_sessions	9	Indexed on (user_id, logged_in_at) and session_id.
users	11	role, is_active, approval_limit. Indexed on role.
drivers	8	Filtered unique index on user_id WHERE user_id IS NOT NULL — SQL Server treats multiple NULLs as duplicates, so a plain unique index would permit only one driver without an account.
customers, items, vehicles, sales_employees, vat_codes, warehouses	7–10	Master data; unique business codes throughout.

SQL Server behaviours that shaped the schema

- Multiple NULLs count as duplicates in a **UNIQUE** index → filtered index for the driver link.
- **UPDATE** does not accept **ORDER BY** → resolve the target id first, then update.
- Multiple cascade paths into one table are rejected → no cascade on the second user FK.
- A busy or under-resourced instance is slow to answer the pre-login handshake → **login_timeout** is configurable.

11. Request lifecycles

11.1 Saving an A/R invoice

```

Browser (Add & New)
└─ ArInvoice::save()
  └─ form->getState()           validation runs here
  └─ InvoiceWriter::store($state, $userId)
    └─ reject blank lines / empty document
    └─ resolve VAT rates from VatCode      (never from posted state)
    └─ InvoiceCalculator::documentTotals() (recomputed server-side)
    └─ DB::transaction
      └─ DocumentNumberService::next()    SELECT ... FOR UPDATE
      └─ Invoice::create(...)              master-data snapshots
      └─ InvoiceLine::create() ×N
      └─ ApprovalService::requestIfNeeded()
    └─ Notification + form reset

```

Auditable fires on each create → audit_logs rows attributed to the user.

11.2 Receiving an M-Pesa payment

```

Safaricom POST /api/mpesa/c2b/confirmation
└─ mpesa.callback middleware      IP allow-list
└─ throttle:mpesa                short code + MSISDN
└─ MpesaC2BCallbackRequest
  └─ CallbackNormaliser          flatten STK shape if nested
  └─ cast scalars to strings
  └─ rules()                     → 422 in ResultCode shape on failure
└─ MpesaC2BController::ingest()
  └─ MpesaC2BService::store()
    └─ updateOrCreate on (trans_id, callback_type) ← idempotency
    └─ failed STK push → allocation_status = N/A, stop
    └─ dispatch C2bConfirmationReceived
      └─ AllocateMpesaReceipt (listener)
        └─ PaymentAllocationService::autoAllocate()
          └─ findInvoiceByReference(BillRefNumber)
            └─ DB::transaction: lock invoice + receipt,
              cap at balance, write allocation,
              recompute both sides from the rows
        └─ 200 { ResultCode: 0, data: { fields, missing, unmapped } }

```

11.3 A vehicle movement

Gate In	Gate Out
GateService::gateIn()	GateService::gateOut()
DB::transaction	DB::transaction
lock vehicle row	lock open gate log
reject if already inside	reject if not inside
snapshot driver details	stamp time_out + user
stamp time_in + user	status → OUT
status → IN	

12. Cross-cutting decisions

Decision	Reasoning
Services, not repositories	Eloquent already abstracts persistence; a second interface would never vary. Query logic lives in scopes, writes in services. See §1.2.
One calculator	The live form and the save path must never disagree, or a user could post totals that do not match their lines.
Recompute, never trust	Totals, VAT rates and balances are all derived server-side. Posted values are display state.
Snapshot master data	A posted document must not change because someone renamed a customer.
Lock, don't hope	Document numbering, approvals, gate movements, trip assignment and payment allocation all take row locks inside a transaction.
Derive from rows	Applied and balance are summed from allocations rather than incremented, so they cannot drift from the records that justify them.
Fail loudly on invariants	<code>DocumentNumberService</code> refuses to run outside a transaction rather than silently issuing duplicates.
Never leak internals	5xx messages are generic; audit logs strip anything secret-shaped by name <i>and</i> by pattern.
Whitelist browser input	The picker takes a registry key, never a model or query; state paths are checked for prefix and wildcards.
Say what is not built	Copy To is disabled with a tooltip; TIMS/ETIMS fields are read-only and marked "Not transmitted". A control that looks live and does nothing is worse than one that admits its state.

13. Testing

190 tests · 702 assertions · 61% coverage. They run against a real SQL Server database (`gil_assessment_test`), not SQLite, so row locking, IDENTITY columns and nvarchar limits behave as in production.

Suite	Covers
Unit/InvoiceCalculatorTest	Discount maths, rounding, blank rows, out-of-range discounts, per-field display precision.
Unit/InvoiceTaxAndTotalsTest	VAT on lines, discount scaling tax, freight, down payments, rounding, non-negative balance.
Unit/CallbackNormaliserTest	Both payload shapes, failed pushes, malformed metadata.
Unit/UserRoleTest	The role × capability matrix, asserted exhaustively.
ArInvoiceScreenTest	Auto-population, sequential numbering, approval threshold, both discount validations, mandatory remarks, server-side recalculation, CFL state-path safety.
ApprovalWorkflowTest · ApprovalIntegrityTest	Routing, drafts bypassing approval, approve/reject, double-decision guard, per-user limits; and the stuck-invoice invariant plus its repair.
PaymentReconciliationTest	Auto-matching, reference formats, ambiguity refusal, overpayment, unmatched queue, retries, manual allocation, unallocation.
MpesaC2BApiTest · MpesaStkCallbackTest · MpesaCaptureDecouplingTest · DarajaClientTest	Field-by-field persistence, idempotency, STK flattening, capture surviving a failing allocator, OAuth and RegisterURL (HTTP faked throughout).
GateOperationsTest	Auto-captured time/user, driver auto-population, double gate-in, gate-out filtering, login/logout sessions.
DriverPortalTest	Driver isolation — own trips only, foreign ids refused, unlinked accounts see nothing, lifecycle, double-booking.
AuditLogTest	Actor capture, changed-fields only, no-op suppression, secrets never recorded , immutability.
UserManagementTest	Admin-only access, hashing, blank-password edits, self-lockout guards, driver linking and relinking.
ErrorHandlingTest	Status mapping, no leakage of SQL or secrets in 5xx , ResultCode shape on M-Pesa routes.
RoleAccessTest · ChooseFromListRegistryTest · DocumentNumberServiceTest	Role matrix, picker whitelist, numbering concurrency.

Reading the coverage figure honestly: 61% is held down by Filament resource scaffolding (tables, forms, list pages) at 0% — declarative configuration with no branching. The business logic is where it should be:

InvoiceCalculator, GateService, InvoiceWriter, CallbackNormaliser and ChooseFromListRegistry at 100%; Auditable 97.7%, ApprovalService 97.9%, MpesaC2BService 97.8%, DarajaClient 96.7%, PaymentAllocationService 89.9%, TripService 87.0%.

14. Operations runbook

Environment

```
DB_CONNECTION=sqlsrv          MPESA_ENVIRONMENT=sandbox
DB_HOST=127.0.0.1            MPESA_CONSUMER_KEY=
DB_PORT=1433                 MPESA_CONSUMER_SECRET=
DB_DATABASE=gil_assessment   MPESA_SHORTCODE=
DB_ENCRYPT=yes               MPESA_RESPONSE_TYPE=Completed
DB_TRUST_SERVER_CERTIFICATE=true
MPESA_ALLOWED_IPS=          # empty = accept any (sandbox/local)
```

Commands

Command	Purpose
<code>php artisan migrate --seed</code>	Schema plus demo data (4 roles, customers, items, vehicles, drivers, routes, trips).
<code>php artisan test</code>	Full suite. <code>--coverage</code> for the report.
<code>php artisan scribe:generate</code>	Rebuild the API docs at <code>/docs</code> , <code>/docs.openapi</code> , <code>/docs.postman</code> .
<code>php artisan mpesa:register-urls --status</code>	Show Daraja configuration; drop <code>--status</code> to register.
<code>php artisan invoices:repair-approvals --dry</code>	Find invoices stuck pending with no request.
<code>bin/reap-act-containers.sh</code>	Remove leaked local-CI containers that starve SQL Server.

Sign-in accounts (seeded, password `password`)

Email	Role	Sees
<code>admin@gil.test</code>	Administrator	Everything, including master data and the audit log
<code>sales@gil.test</code>	Sales	A/R Invoice, Invoice Register, payments
<code>approver@gil.test</code>	Approver	The approval queue (limit 50,000)
<code>gate@gil.test</code>	Gate Officer	Gate In / Out / Log, routes and trips
<code>driver@gil.test</code>	Driver	Only their own trips

Known limits

- Decimal places follow the sample document (4 / 6 / 2) rather than the brief's "up to 3" — a deliberate departure, recorded here.
- Logistics, Accounting, TIMS and ETIMS tabs are structural; eTIMS transmission is a KRA integration outside this scope.
- Posted invoices are not editable; drafts exist for work in progress.
- Copy To awaits a downstream document type.